



Security Audit

CatSwap (DEX)

Table of Contents

Executive Summary	4
Project Context	4
Audit Scope	7
Security Rating	8
Intended Smart Contract Functions	9
Code Quality	10
Audit Resources	10
Dependencies	10
Severity Definitions	11
Status Definitions	12
Audit Findings	13
Centralisation	17
Conclusion	18
Our Methodology	19
Disclaimers	21
About Hashlock	22

CAUTION

THIS DOCUMENT IS A SECURITY AUDIT REPORT AND MAY CONTAIN CONFIDENTIAL INFORMATION. THIS INCLUDES IDENTIFIED VULNERABILITIES AND MALICIOUS CODE WHICH COULD BE USED TO COMPROMISE THE PROJECT. THIS DOCUMENT SHOULD ONLY BE FOR INTERNAL USE UNTIL ISSUES ARE RESOLVED. ONCE VULNERABILITIES ARE REMEDIATED, THIS REPORT CAN BE MADE PUBLIC. THE CONTENT OF THIS REPORT IS OWNED BY HASHLOCK PTY LTD FOR USE OF THE CLIENT.

Executive Summary

The CatSwap team partnered with Hashlock to conduct a security audit of their smart contracts. Hashlock manually and proactively reviewed the code in order to ensure the project's team and community that the deployed contracts are secure.

Project Context

CatSwap is a decentralized Automated Market Maker (AMM) swap platform built on Bitcoin Layer 1 technologies—including BRC-20, BRC 2.0, CAT20, DRC-20, Alkanes, and Runes. It leverages the power of the OP_CAT covenant to enable fully on-chain token swapping without reliance on off-chain indexers or centralized intermediaries, ensuring trustless, censorship-resistant operations that are atomic and secure by design. CatSwap operates across not only Bitcoin but also compatible networks like Fractal Bitcoin and even Dogecoin, positioning itself as a pioneering protocol in the BTCFi (Bitcoin finance) ecosystem.

Project Name: CatSwap

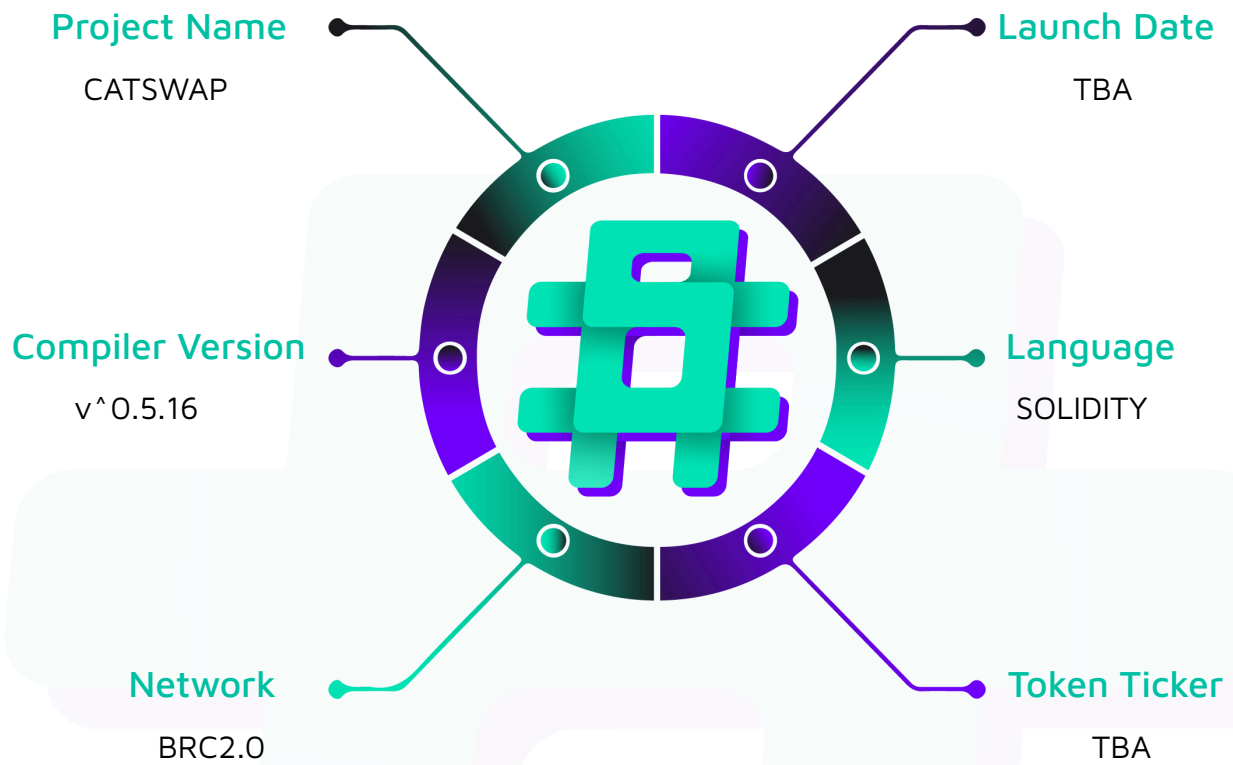
Project Type: DEX

Compiler Version: ^0.5.16

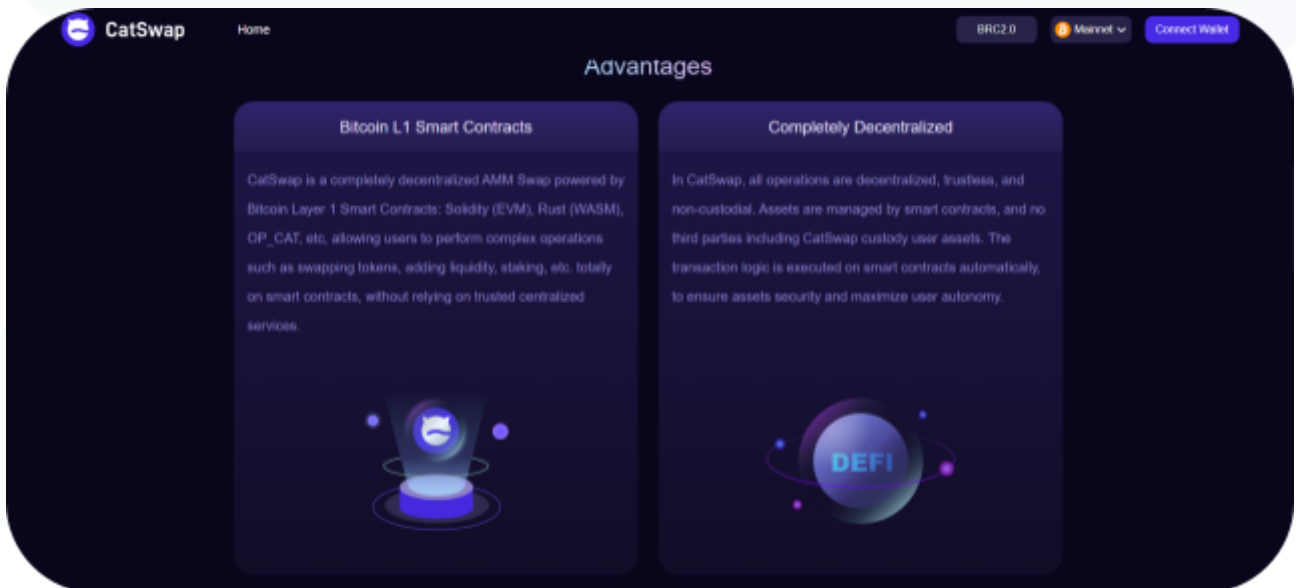
Website: <https://catswap.fun/>

Logo:



Visualised Context:

Project Visuals:



Audit Scope

We at Hashlock audited the solidity code within the CatSwap project, the scope of work included a comprehensive review of the smart contracts listed below. We tested the smart contracts to check for their security and efficiency. These tests were undertaken primarily through manual line-by-line analysis and were supported by software-assisted testing.

Description	CatSwap Smart Contracts
Platform	BRC2.0 / Solidity
Audit Date	September, 2025
Contract 1	CatSwapFactory.sol
Contract 2	CatSwapRouter02.sol
Audited GitHub Commit Hash	660548f030a6e202b5d1fd8e8bd2b0d4d64f72be
Fix Review GitHub Commit Hash	ed861e16da85158d04a917fb31cbf2712ad362b8
Contract 1 Address Fix Review	0xE710c5A54c3720456902824ffaC6444dB4eD3B41
Contract 2 Address Fix Review	0x5168F7A79B3CcbE94eE1e8a095Aaa1f035bD98e8

Security Rating

After Hashlock's Audit, we found the smart contracts to be **"Secure"**. The contracts all follow simple logic, with correct and detailed ordering. They use a series of interfaces, and the protocol uses a list of Open Zeppelin contracts.



The 'Hashlocked' rating is reserved for projects that ensure ongoing security via bug bounty programs or on chain monitoring technology.

All issues uncovered during automated and manual analysis were meticulously reviewed and applicable vulnerabilities are presented in the [Audit Findings](#) section. The list of audited assets is presented in the [Audit Scope](#) section and the project's contract functionality is presented in the [Intended Smart Contract Functions](#) section.

All vulnerabilities initially identified have now been acknowledged.

Hashlock found:

3 Low severity vulnerabilities

1 QA

Caution: *Hashlock's audits do not guarantee a project's success or ethics, and are not liable or responsible for security. Always conduct independent research about any project before interacting.*

Intended Smart Contract Functions

Claimed Behaviour	Actual Behaviour
CatSwapFactory.sol Allows users to: - Create a new liquidity pool (trading pair) for any two ERC20 tokens. - Look up the address of an existing token pair. Allows admins to: - Set an address to receive a portion of the trading fees (protocol fees). - Transfer the admin role (feeToSetter) to a new address.	Contract achieves this functionality.
CatSwapRouter02.sol Allows users to: - Add liquidity to a token pair pool to earn trading fees. - Remove their liquidity from a pool at any time. - Swap one ERC20 token for another through the liquidity pools. - Calculate expected trade amounts and prices without executing a swap.	Contract achieves this functionality.

Code Quality

This audit scope involves the smart contracts of the CatSwap project, as outlined in the Audit Scope section. All contracts, libraries, and interfaces mostly follow standard best practices and to help avoid unnecessary complexity that increases the likelihood of exploitation, however, some refactoring were recommended to optimize security measures.

The code is very well commented on and closely follows best practice nat-spec styling. All comments are correctly aligned with code functionality.

Audit Resources

We were given the CatSwap project smart contract code in the form of GitHub access.

As mentioned above, code parts are well commented. The logic is straightforward, and therefore it is easy to quickly comprehend the programming flow as well as the complex code logic. The comments are helpful in providing an understanding of the protocol's overall architecture.

Dependencies

As per our observation, the libraries used in this smart contracts infrastructure are based on well-known industry standard open source projects.

Apart from libraries, its functions are used in external smart contract calls.

Severity Definitions

The severity levels assigned to findings represent a comprehensive evaluation of both their potential impact and the likelihood of occurrence within the system. These categorizations are established based on Hashlock's professional standards and expertise, incorporating both industry best practices and our discretion as security auditors. This ensures a tailored assessment that reflects the specific context and risk profile of each finding.

Significance	Description
High	High-severity vulnerabilities can result in loss of funds, asset loss, access denial, and other critical issues that will result in the direct loss of funds and control by the owners and community.
Medium	Medium-level difficulties should be solved before deployment, but won't result in loss of funds.
Low	Low-level vulnerabilities are areas that lack best practices that may cause small complications in the future.
Gas	Gas Optimisations, issues, and inefficiencies.
QA	Quality Assurance (QA) findings are informational and don't impact functionality. Supports clients improve the clarity, maintainability, or overall structure of the code.

Status Definitions

Each identified security finding is assigned a status that reflects its current stage of remediation or acknowledgment. The status provides clarity on the handling of the issue and ensures transparency in the auditing process. The statuses are as follows:

Significance	Description
Resolved	The identified vulnerability has been fully mitigated either through the implementation of the recommended solution proposed by Hashlock or through an alternative client-provided solution that demonstrably addresses the issue.
Acknowledged	The client has formally recognized the vulnerability but has chosen not to address it due to the high cost or complexity of remediation. This status is acceptable for medium and low-severity findings after internal review and agreement. However, all high-severity findings must be resolved without exception.
Unresolved	The finding remains neither remediated nor formally acknowledged by the client, leaving the vulnerability unaddressed.

Audit Findings

Low

[L-01] CatSwapFactory#setFeeToSetter - feeToSetter Role Lacks Zero Address

Validation

Vulnerability Details

The `feeToSetter` address, which holds administrative control over protocol fees, is not validated against the zero address in two critical locations. The constructor does not validate the initial `_feeToSetter`, allowing the contract to be deployed into a broken state. Additionally, the `setFeeToSetter` function allows the role to be transferred to the zero address, which would permanently burn the administrative function and lock fee management forever.

```
constructor(address _feeToSetter) public {//@audit - no zero address check

    feeToSetter = _feeToSetter;

}

function setFeeToSetter(address _feeToSetter) external {//@audit - no zero address check

    require(msg.sender == feeToSetter, 'CatSwap: FORBIDDEN');

    feeToSetter = _feeToSetter;

}
```

Recommendation

Add a `require` statement checking that the `_feeToSetter` address is not `address(0)` in both the constructor and the `setFeeToSetter` function.

Status

Acknowledged

[L-02] CatSwapFactory#setFeeToSetter&setFeeTo - Administrative Functions Lack Events

Vulnerability Details

The `setFeeTo` and `setFeeToSetter` functions modify critical protocol addresses without emitting events. This lack of on-chain logging makes it difficult for users and off-chain applications to transparently track important administrative changes to the protocol's fee structure and ownership.

Recommendation

Implement and emit events within the `setFeeTo` and `setFeeToSetter` functions. The events should log the previous and the new address for each respective state change.

Status

Acknowledged

[L-03] CatSwapRouter02# - Inconsistent and Outdated Solidity Versions in Core Contracts

Vulnerability Details

The `CatSwapFactory.sol` and `CatSwapRouter02.sol` contracts are using different and outdated Solidity compiler versions (0.5.16 and 0.6.6, respectively). This version mismatch can cause ABI incompatibilities and integration bugs. Furthermore, using older compiler versions introduces significant security risks, as they often contain known vulnerabilities that have been patched in more recent releases.

Recommendation

To enhance security and ensure protocol stability, both contracts should be upgraded to the same recent Solidity version.

Status

Acknowledged

QA

[Q-01] CatSwapRouter02#removeLiquidity - Use of `transferFrom` instead of `safeTransferFrom` in `removeLiquidity`

Description

The `removeLiquidity` function uses a direct call to `transferFrom` when handling the protocol's LP tokens. Because the LP token is a trusted, standard-compliant contract controlled by the protocol, this does not pose a direct risk to user funds. However, it is inconsistent within the codebase and best practices for token interactions.

Recommendation

For improved code consistency and to strictly adhere to best practices, consider using `safeTransferFrom` method.

Status

Acknowledged

Centralisation

The CatSwap project values security and utility over decentralisation.

The owner executable functions within the protocol increase security and functionality but depend highly on internal team responsibility.



Centralised

Decentralised

Conclusion

After Hashlock's analysis, the CatSwap project seems to have a sound and well-tested code base, now that our vulnerability findings have been acknowledged. Overall, most of the code is correctly ordered and follows industry best practices. The code is well commented on as well. To the best of our ability, Hashlock is not able to identify any further vulnerabilities.

Our Methodology

Hashlock strives to maintain a transparent working process and to make our audits a collaborative effort. The objective of our security audits is to improve the quality of systems and upcoming projects we review and to aim for sufficient remediation to help protect users and project leaders. Below is the methodology we use in our security audit process.

Manual Code Review:

In manually analysing all of the code, we seek to find any potential issues with code logic, error handling, protocol and header parsing, cryptographic errors, and random number generators. We also watch for areas where more defensive programming could reduce the risk of future mistakes and speed up future audits. Although our primary focus is on the in-scope code, we examine dependency code and behaviour when it is relevant to a particular line of investigation.

Vulnerability Analysis:

Our methodologies include manual code analysis, user interface interaction, and white box penetration testing. We consider the project's website, specifications, and whitepaper (if available) to attain a high-level understanding of what functionality the smart contract under review contains. We then communicate with the developers and founders to gain insight into their vision for the project. We install and deploy the relevant software, exploring the user interactions and roles. While we do this, we brainstorm threat models and attack surfaces. We read design documentation, review other audit results, search for similar projects, examine source code dependencies, skim open issue tickets, and generally investigate details other than the implementation.

Documenting Results:

We undergo a robust, transparent process for analysing potential security vulnerabilities and seeing them through to successful remediation. When a potential issue is discovered, we immediately create an issue entry for it in this document, even though we have not yet verified the feasibility and impact of the issue. This process is vast because we document our suspicions early even if they are later shown to not represent exploitable vulnerabilities. We generally follow a process of first documenting the suspicion with unresolved questions, and then confirming the issue through code analysis, live experimentation, or automated tests. Code analysis is the most tentative, and we strive to provide test code, log captures, or screenshots demonstrating our confirmation. After this, we analyse the feasibility of an attack in a live system.

Suggested Solutions:

We search for immediate mitigations that live deployments can take and finally, we suggest the requirements for remediation engineering for future releases. The mitigation and remediation recommendations should be scrutinised by the developers and deployment engineers, and successful mitigation and remediation is an ongoing collaborative process after we deliver our report, and before the contract details are made public.

Disclaimers

Hashlock's Disclaimer

Hashlock's team has analysed these smart contracts in accordance with the best industry practices at the date of this report, in relation to: cybersecurity vulnerabilities and issues in the smart contract source code, the details of which are disclosed in this report, (Source Code); the Source Code compilation, deployment, and functionality (performing the intended functions).

Due to the fact that the total number of test cases is unlimited, the audit makes no statements or warranties on the security of the code. It also cannot be considered as a sufficient assessment regarding the utility and safety of the code, bug-free status, or any other statements of the contract. While we have done our best in conducting the analysis and producing this report, it is important to note that you should not rely on this report only. We also suggest conducting a bug bounty program to confirm the high level of security of this smart contract.

Hashlock is not responsible for the safety of any funds and is not in any way liable for the security of the project.

Technical Disclaimer

Smart contracts are deployed and executed on a blockchain platform. The platform, its programming language, and other software related to the smart contract can have their own vulnerabilities that can lead to attacks. Thus, the audit can't guarantee the explicit security of the audited smart contracts.

About Hashlock

Hashlock is an Australian-based company aiming to help facilitate the successful widespread adoption of distributed ledger technology. Our key services all have a focus on security, as well as projects that focus on streamlined adoption in the business sector.

Hashlock is excited to continue to grow its partnerships with developers and other web3-oriented companies to collaborate on secure innovation, helping businesses and decentralised entities alike.

Website: hashlock.com.au

Contact: info@hashlock.com.au



#hashlock.